TITLE: APPLICATION-SPECIFIC ACCESS POLICIES USING ZSCALER PRIVATE ACCESS (ZPA)

INTRODUCTION

In the modern digital era, organizations depend heavily on cloud services, remote work environments, and internet-connected systems. While these technologies improve productivity and flexibility, they also introduce significant cybersecurity risks. Traditional network security approaches such as perimeter-based security models and Virtual Private Networks (VPNs) are no longer sufficient to protect organizational resources.

In the traditional model, once a user is authenticated through a VPN, they often receive broad network access. This means that even if the user only needs access to one application, they may still be able to access many other systems within the network. This increases the risk of lateral movement, where attackers move within the network after gaining access.

To solve this problem, modern security frameworks adopt the Zero Trust Architecture (ZTA). The Zero Trust model follows the principle of “Never Trust, Always Verify.” Every user, device, and application must be verified before access is granted.

One of the most powerful solutions implementing Zero Trust security is Zscaler Private Access (ZPA). ZPA provides secure access to internal applications without exposing them to the public internet. Instead of providing network-level access like VPNs, ZPA grants application-level access based on identity, device posture, and access policies.

This project focuses on implementing least-privilege access control using Zscaler Private Access. The least-privilege principle ensures that users only receive the minimum level of access required to perform their tasks. By applying identity-aware and application-specific access policies, organizations can significantly reduce attack surfaces and improve cybersecurity resilience.

The project also includes vulnerability assessment using security tools, analysis of system vulnerabilities, and implementation of security monitoring strategies such as SOC, SIEM, and threat intelligence platforms.

ABSTRACT

Cybersecurity threats such as malware attacks, data breaches, and unauthorized system access have become major concerns for organizations worldwide. With the increase in remote work and cloud adoption, traditional network security methods are no longer sufficient to protect sensitive data and applications.

This project focuses on implementing a Zero Trust security model using Zscaler Private Access (ZPA) to enforce least-privilege access to organizational applications. Instead of providing full network access, ZPA allows users to connect only to the specific applications they are authorized to use.

The system verifies user identity through an identity provider and evaluates device security posture before allowing access. This ensures that only authenticated and compliant devices can access internal resources.

In addition to implementing ZPA policies, the project also includes vulnerability scanning using tools such as Tenable Nessus, analysis of identified vulnerabilities, and recommendations for mitigation. Security monitoring concepts such as Security Operations Center (SOC), Security Information and Event Management (SIEM), and Malware Information Sharing Platform (MISP) are also explored.

The objective of this project is to demonstrate how modern cybersecurity technologies and Zero Trust principles can protect organizational systems from cyber threats and unauthorized access.

USECASE SCENARIOS

Scenario 1: Finance Department Access to ERP System

The finance department uses the ERP system to manage payroll, accounting, and financial records. Only authorized finance employees should be able to access this system. When a user tries to access the ERP system, their identity is verified through an authentication process. Zscaler Private Access checks whether the user belongs to the finance department. If the verification is successful, the system allows access only to the ERP application. This ensures that sensitive financial data remains secure and protected from unauthorized users.

Scenario 2: Contractor Access to Specific Project Repository

Organizations sometimes hire external contractors to work on specific projects. These contractors may need access to a project repository to view or update files. Using Zscaler Private Access, the contractor must first authenticate their identity. The system checks whether the contractor is authorized to access the repository. If approved, access is granted only to the specific project repository. Other internal systems remain hidden and inaccessible to the contractor.

Scenario 3: Executive Access to Confidential Board Documents

Executives and board members often need access to confidential company documents. These documents may include business strategies and financial reports. Zscaler Private Access ensures that only authorized executives can access these files. The system verifies the user's identity and device security before granting access. After verification, the executive can securely view the documents. This process protects sensitive company information from unauthorized access.

Scenario 4: IT Administrator Access to Server Management Interfaces

IT administrators are responsible for managing servers and network systems. They need secure access to server management tools to perform their tasks. When an administrator tries to access the server interface, their identity is verified. Zscaler Private Access checks if the administrator has the required permissions. If the verification is successful, access to the server management interface is granted. All activities are monitored to maintain system security.

Scenario 5: Mergers and Acquisitions Integration

When two companies merge, employees from both organizations need to work together. However, they should not get full access to all internal systems immediately. Zscaler Private Access allows administrators to control which applications new employees can access. The system verifies the identity of users before granting access. Only the necessary applications are made available for collaboration. This helps maintain security during the integration process.

STAGE 1

TITLE: APPLICATION-SPECIFIC ACCESS POLICIES USING ZSCALER PRIVATE ACCESS (ZPA)

COLLEGE NAME: KPR COLLEGE OF ARTS SCIENCE AND RESEARCH

DEPARTMENT: B.Sc. COMPUTER SCIENCE WITH DATA ANALYTICS

TEAM DETAILS:

SNO	REGISTER NUMBER	NAME	COLLEGE	EMAIL ID
1	2328B0035	JENI JOSPHIN A (TEAM LEADER)	KPRCAS	23bda025@kprcas.ac.in
2	2328B0066	SARAVANAKUMAR P	KPRCAS	23bda056@kprcas.ac.in
3	2328B0068	SHREYAS S	KPRCAS	23bda058@kprcas.ac.in
4	2328B0016	BALAVIGNESH P	KPRCAS	23bda006@kprcas.ac.in
5	2328B0043	MAGUDESHWARAN G	KPRCAS	23bda033@kprcas.ac.in

INTRODUCTION:

In today's digital environment, organizations face many cybersecurity threats when users access systems from different locations and devices. Traditional security methods that only rely on usernames and passwords are no longer sufficient to protect sensitive data.

This project focuses on designing and applying context-aware access control, which is a modern security approach that evaluates multiple factors before allowing access to an application. These factors include the user's identity, the security condition of the device, the location from which the user is accessing the system, and the risk level of the application.

The system analyzes these conditions in real time and decides whether to allow access, restrict certain actions, request additional authentication such as multi-factor authentication (MFA), or block the access completely.

The goal of this project is to improve cybersecurity by implementing a Zero Trust security model, where every access request is verified before granting permission. This helps organizations protect sensitive data, prevent unauthorized access, and ensure secure usage of applications from any device or location.

VULNERBILITY TABLE

S. No.	VULNERBILITY NAME	CWE NO
1	Cross Site Scripting (Stored)	CWE-79
2	Broken Access Control	CWE-285
3	SQL Injection	CWE- 89
4	Broken Authentication	CWE- 285
5	Insecure Direct Object Reference	CWE- 639
6	Security Misconfiguration	CWE- 732
7	Cross Site Request Forgery	CWE- 352
8	Cleartext Transmission of Sensitive Information	CWE- 319
9	Clickjacking	CWE- 1021
10	Password Auto Completion Enabled	CWE- 310
11	DOM Based Cross Site Scripting	CWE- 79

12	JQuery Multiple XSS	CWE- 79
13	Information Exposure (HTTP Header Internal IP Disclosure)	CWE- 200
14	Information Exposure (SSL Issues)	CWE- 200
15	Information Exposure (HTTP Issues)	CWE- 200
16	OS Identification Failed	CWE- 200

1. **Vulnerability Name: Cross-Site Scripting (Stored)**

CWE Number: CWE-79

Description : Cross-Site Scripting (XSS) is a web security vulnerability where attackers insert malicious scripts into a web application. These scripts are stored in the server and later executed in the browser of other users who visit the affected page.

Business Impact : This vulnerability can allow attackers to steal sensitive information such as user credentials, session cookies, or personal data. It can also allow attackers to perform actions on behalf of legitimate users.

Vulnerability Path: http://testfire.net/

Vulnerability Parameter: http://testfire.net/search.jsp?query='>alert('hacked')

Steps to Reproduce:

1. Open the website http://testfire.net/.
2. Navigate to the search box in the application.
3. Enter the script '>alert('hacked').
4. Submit the input.
5. A pop-up alert box appears showing “hacked”, confirming the XSS vulnerability.

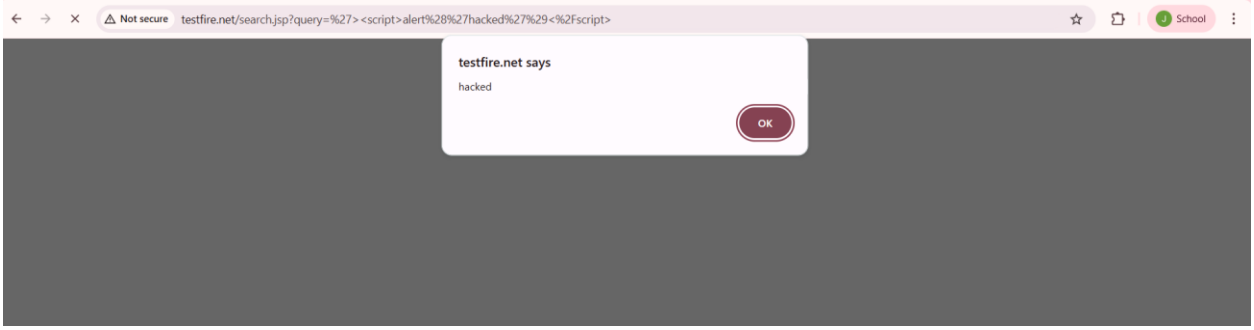
Recommendation:

Validate and sanitize all user inputs.

Use output encoding to prevent script execution.

Implement secure coding practices to prevent injection attacks.

Screenshot:



2. Vulnerability Name: Broken Access Control

CWE No: CWE-285

Description: Broken Access Control occurs when a system does not properly restrict users from accessing data or functions that they are not authorized to use.

Business Impact: Attackers may gain unauthorized access to sensitive data, modify user information, or perform administrative actions.

Vulnerability Path: http://testfire.net/login.jsp

Steps to Reproduce:

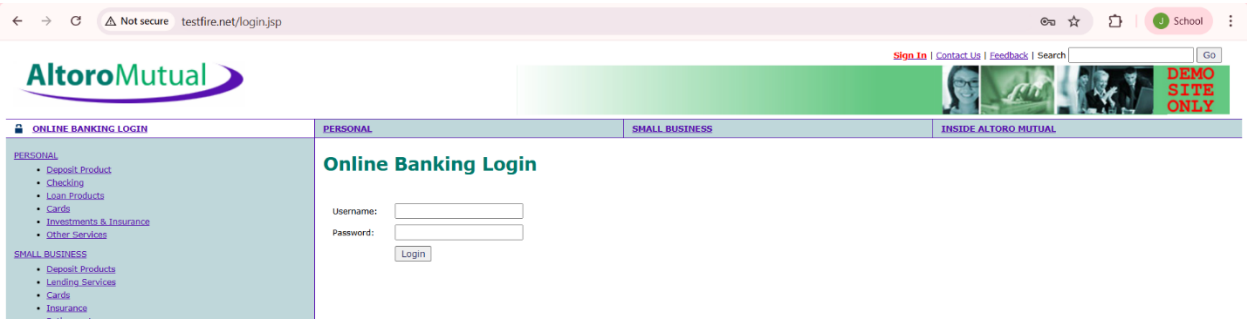
1. Open the website http://testfire.net/.
2. Try logging in using admin credentials.
3. Capture the request using Burp Suite.
4. The request shows username and password in clear text.

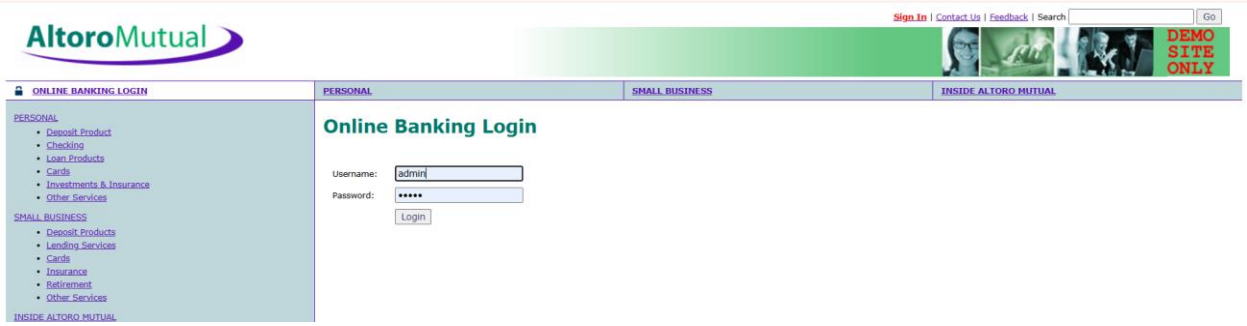
Recommendation:

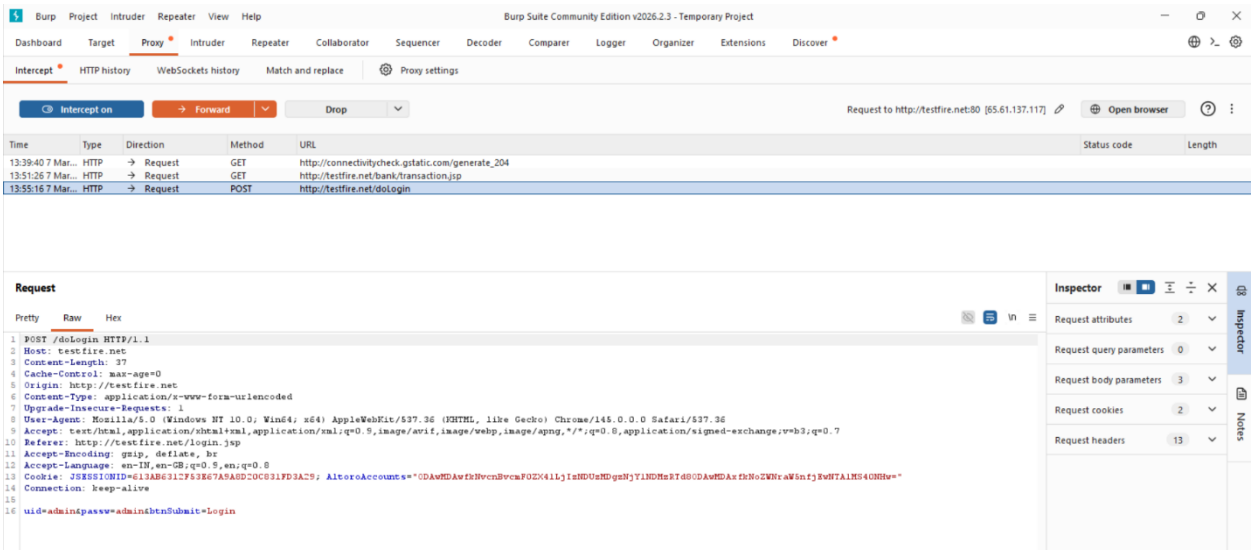
Implement strong authentication and authorization mechanisms.

Use secure session management to protect user access.

Screenshot:







3. Vulnerability Name: SQL Injection

CWE No: CWE-89

Description: SQL Injection occurs when an attacker inserts malicious SQL queries into input fields to manipulate the database.

Business Impact: Attackers can access sensitive data, modify database records, or gain unauthorized administrative access.

Vulnerability Path: http://testfire.net/login.jsp

Steps to Reproduce:

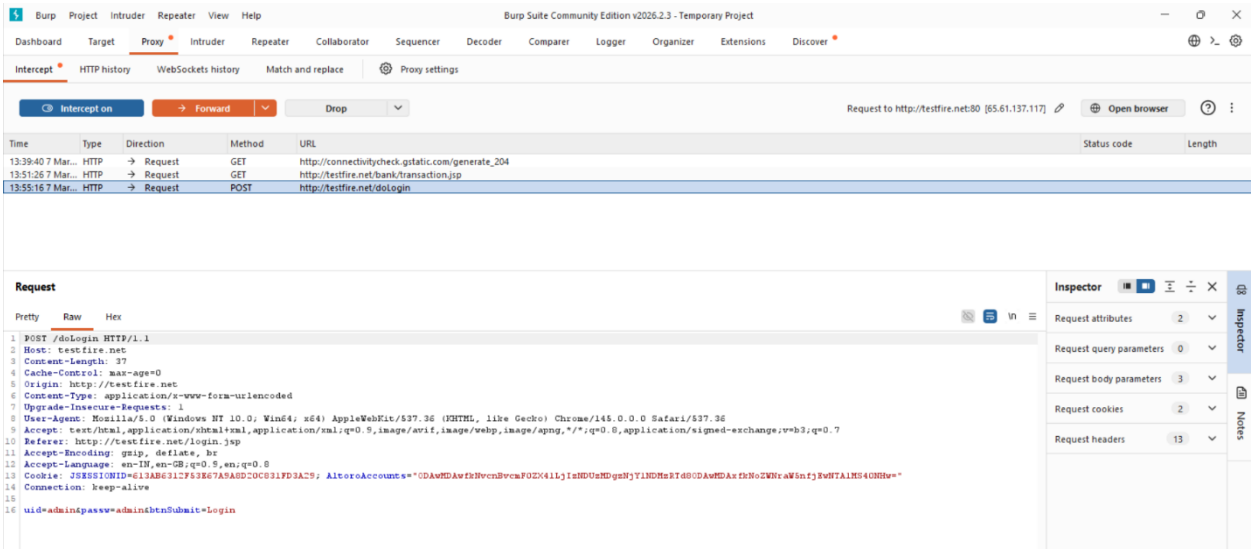
1. Open the website http://testfire.net/.
2. Enter SQL injection payload in the login form.
3. Capture the request using Burp Suite.
4. The attacker may gain admin access without a valid password.

Recommendation:

Use parameterized queries or prepared statements.

Validate and sanitize all user inputs.

Screenshot:



4. Vulnerability Name: Broken Authentication

CWE No: CWE-285

Description: Broken Authentication occurs when the system fails to properly manage user authentication. Attackers can bypass login mechanisms and access other user accounts.

Business Impact: Attackers may gain unauthorized access to user accounts and sensitive information.

Vulnerability Path: http://testfire.net/login.jsp

Steps to Reproduce:

1. Open the website http://testfire.net/.
2. Try logging in with manipulated username inputs.
3. Use SQL injection to bypass password verification.
4. Access to another user account is granted.

Recommendation:

Implement strong authentication mechanisms such as Multi-Factor Authentication (MFA).

Use secure password storage and proper session management.

Screenshot:

5. Vulnerability Name: Insecure Direct Object Reference (IDOR)

CWE No: CWE-639

Description: IDOR occurs when a web application allows users to access or modify data by changing object identifiers such as user IDs or parameters in the URL.

Business Impact: Attackers can access or modify sensitive information of other users without proper authorization.

Vulnerability Path: **http://testfire.net/bank/transfer.jsp**

Steps to Reproduce:

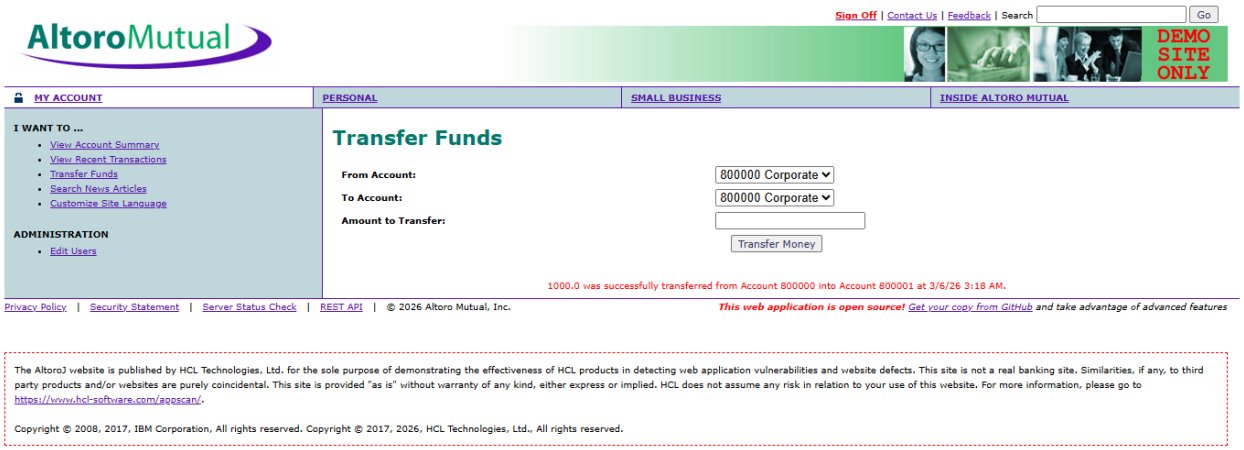
1. Open the website **http://testfire.net/**.
2. Login to the application.
3. Go to the "Transfer Money" section.
4. Intercept the request using Burp Suite and modify the transfer amount.

Recommendation:

Implement proper access control checks.

Validate user permissions before allowing access to sensitive data.

Screenshot:



6. Vulnerability Name : Security Misconfiguration

CWE No : CWE-732

Description : Security Misconfiguration occurs when systems are not securely configured, allowing unauthorized access to sensitive files or directories.

Business Impact : Attackers may access confidential information, system files, or hidden directories due to weak security settings.

Vulnerability Path : **http://testfire.net/**

Steps to Reproduce :

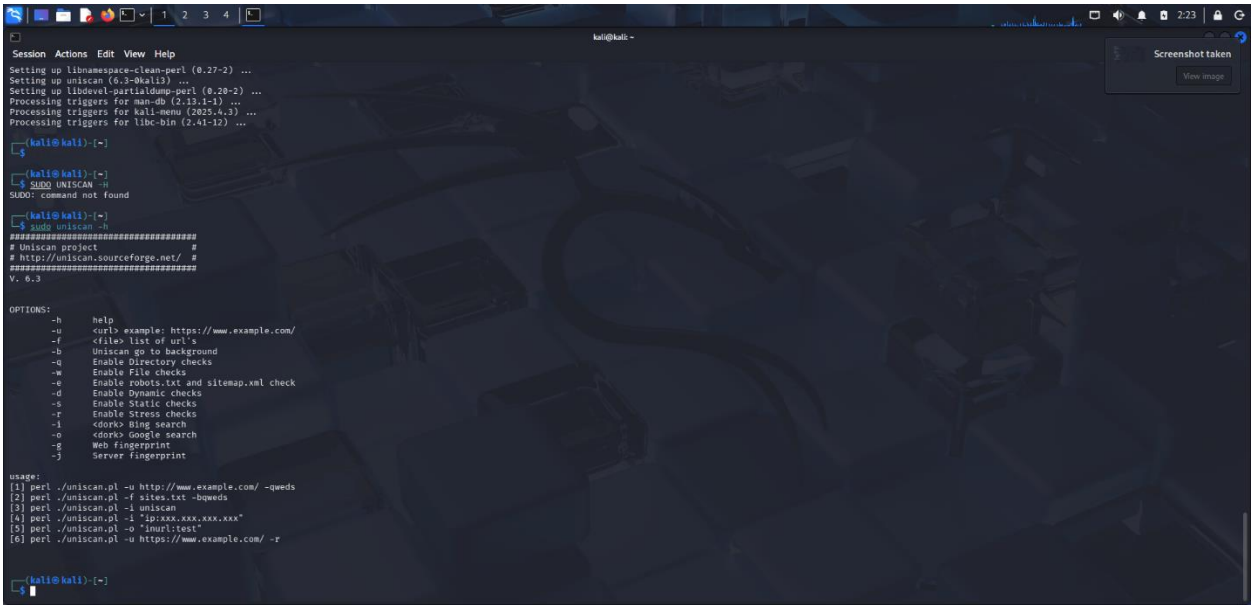
1. Open the website **http://testfire.net/**.
2. Use scanning tools such as Uniscan in Kali Linux.
3. Scan the website for hidden directories.
4. The scan reveals accessible directories and sensitive files.

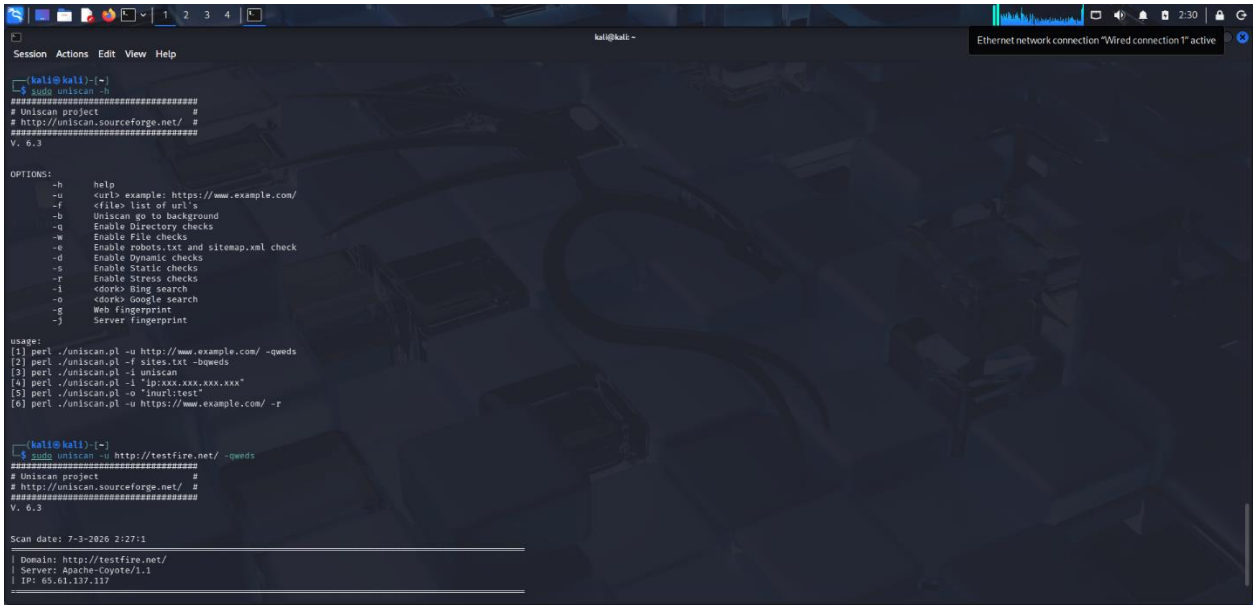
Recommendation :

Apply secure configuration settings for servers and applications.

Regularly perform security audits and vulnerability scans.

Screenshot :





7. **Vulnerability Name : Cross-Site Request Forgery (CSRF)**

CWE No : CWE-352

Description : CSRF is an attack that tricks a logged-in user into performing unwanted actions on a web application without their knowledge.

Business Impact : Attackers can perform actions such as transferring funds or changing user data using the victim's authenticated session.

Vulnerability Path : **http://testfire.net/bank/transfer.jsp**

Steps to Reproduce :

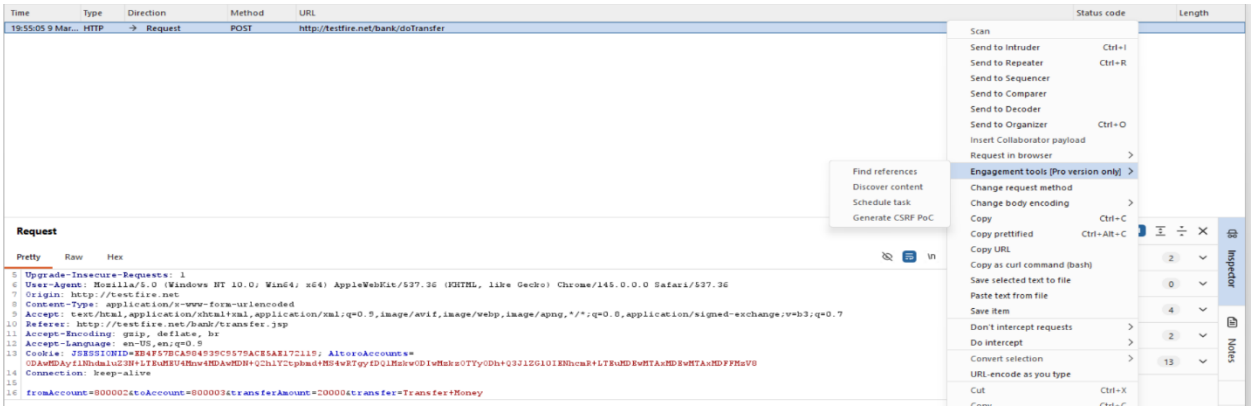
1. Open the website **http://testfire.net/**.
2. Login using valid credentials.
3. Capture the transfer request using Burp Suite.
4. Generate a CSRF proof-of-concept request to perform the action.

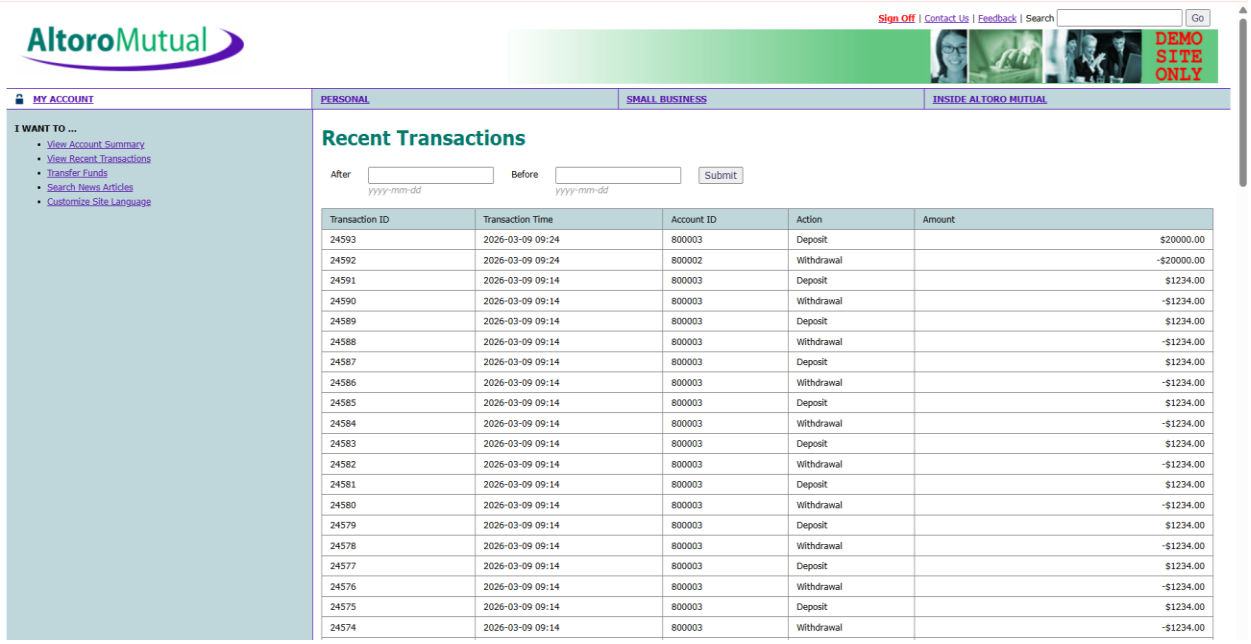
Recommendation :

Implement CSRF tokens to validate requests.

Use secure session management techniques.

Screenshot :





Transaction ID	Transaction Time	Account ID	Action	Amount
24593	2026-03-09 09:24	800003	Deposit	$20000.00
24592	2026-03-09 09:24	800002	Withdrawal	-$20000.00
24591	2026-03-09 09:14	800003	Deposit	$1234.00
24590	2026-03-09 09:14	800003	Withdrawal	-$1234.00
24589	2026-03-09 09:14	800003	Deposit	$1234.00
24588	2026-03-09 09:14	800003	Withdrawal	-$1234.00
24587	2026-03-09 09:14	800003	Deposit	$1234.00
24586	2026-03-09 09:14	800003	Withdrawal	-$1234.00
24585	2026-03-09 09:14	800003	Deposit	$1234.00
24584	2026-03-09 09:14	800003	Withdrawal	-$1234.00
24583	2026-03-09 09:14	800003	Deposit	$1234.00
24582	2026-03-09 09:14	800003	Withdrawal	-$1234.00
24581	2026-03-09 09:14	800003	Deposit	$1234.00
24580	2026-03-09 09:14	800003	Withdrawal	-$1234.00
24579	2026-03-09 09:14	800003	Deposit	$1234.00
24578	2026-03-09 09:14	800003	Withdrawal	-$1234.00
24577	2026-03-09 09:14	800003	Deposit	$1234.00
24576	2026-03-09 09:14	800003	Withdrawal	-$1234.00
24575	2026-03-09 09:14	800003	Deposit	$1234.00
24574	2026-03-09 09:14	800003	Withdrawal	-$1234.00

8. Vulnerability Name : Cleartext Transmission of Sensitive Information

CWE No : CWE-319

Description : This vulnerability occurs when sensitive information such as usernames and passwords is transmitted without encryption over the network.

Business Impact : Attackers can intercept network traffic and capture sensitive information, leading to data breaches and unauthorized access.

Vulnerability Path : http://testfire.net/login.jsp

Steps to Reproduce :

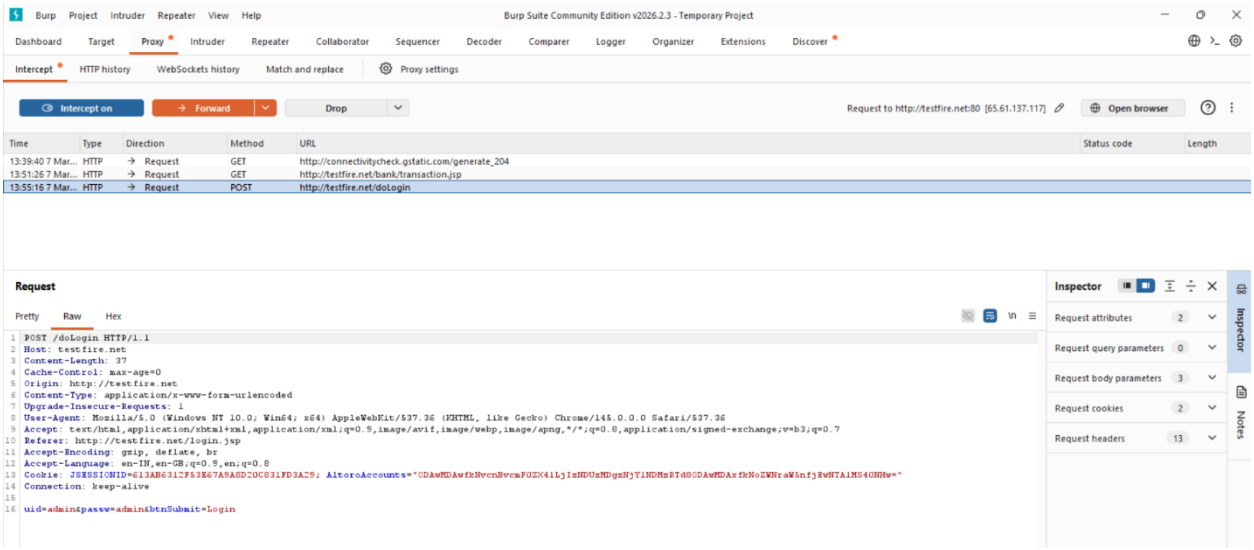
1. Open the website **http://testfire.net/**.
2. Login using admin credentials.
3. Capture the request using Burp Suite.
4. The username and password appear in clear text in the request.

Recommendation :

• Use HTTPS with SSL/TLS encryption.

• Ensure sensitive data is always transmitted securely.

Screenshot :



9. Vulnerability Name : Clickjacking

CWE No : CWE-1021

Description : Clickjacking occurs when a malicious webpage tricks users into clicking hidden buttons or links by placing the target webpage inside an invisible frame.

Business Impact : Attackers can trick users into performing unwanted actions such as clicking buttons, submitting forms, or revealing sensitive information.

Vulnerability Path : **http://testfire.net/**

Steps to Reproduce :

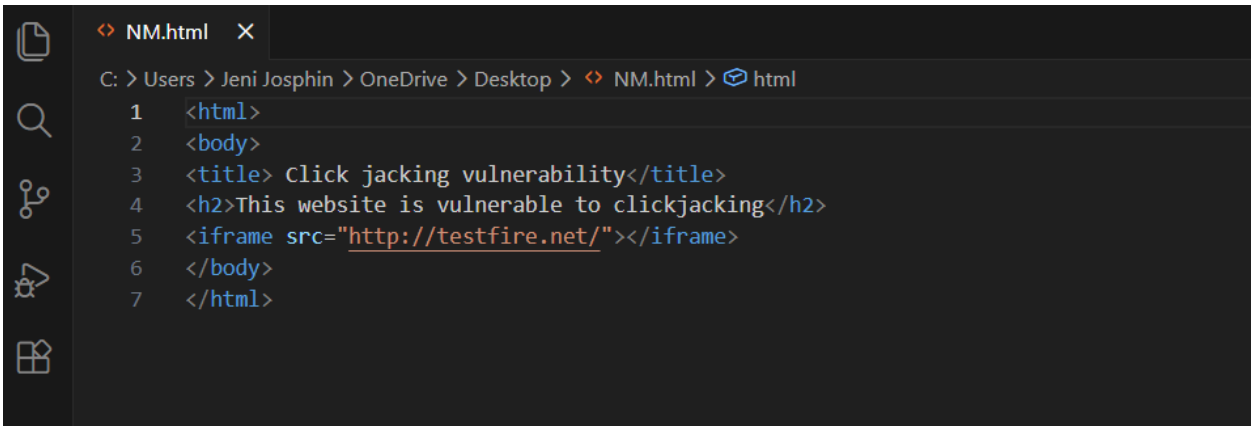
1. Open the target website **http://testfire.net/**.
2. Create an HTML page that loads the site inside an iframe.
3. Run the HTML file in a browser.
4. The website loads inside the frame, confirming the vulnerability.

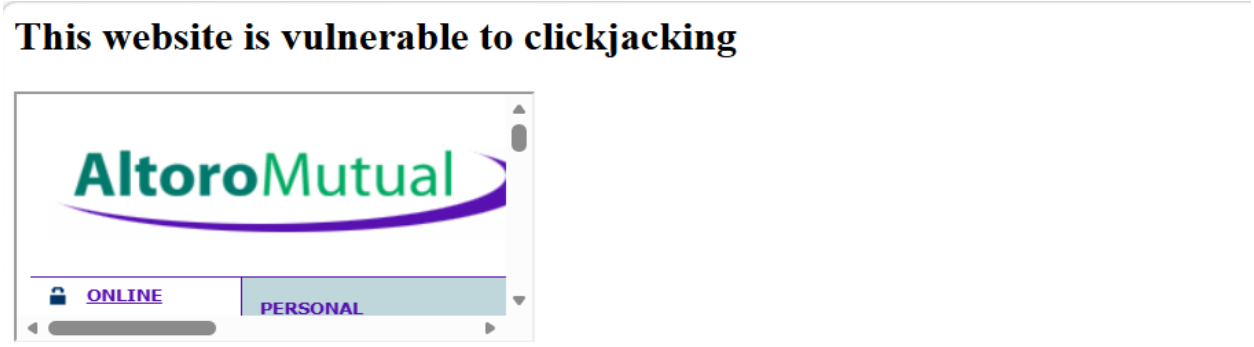
Recommendation :

Use X-Frame-Options header to prevent framing.

Implement Content Security Policy (CSP) to block unauthorized embedding.

Screenshot :





10. Vulnerability Name : Web Server Allows Password Auto-Completion

CWE No : CWE-310SSS

Description : This vulnerability occurs when the web browser automatically fills previously saved usernames and passwords on login pages.

Business Impact : Attackers who gain access to the device can easily view or use stored credentials to access the application.

Vulnerability Path : **http://testfire.net/login.jsp**

Steps to Reproduce :

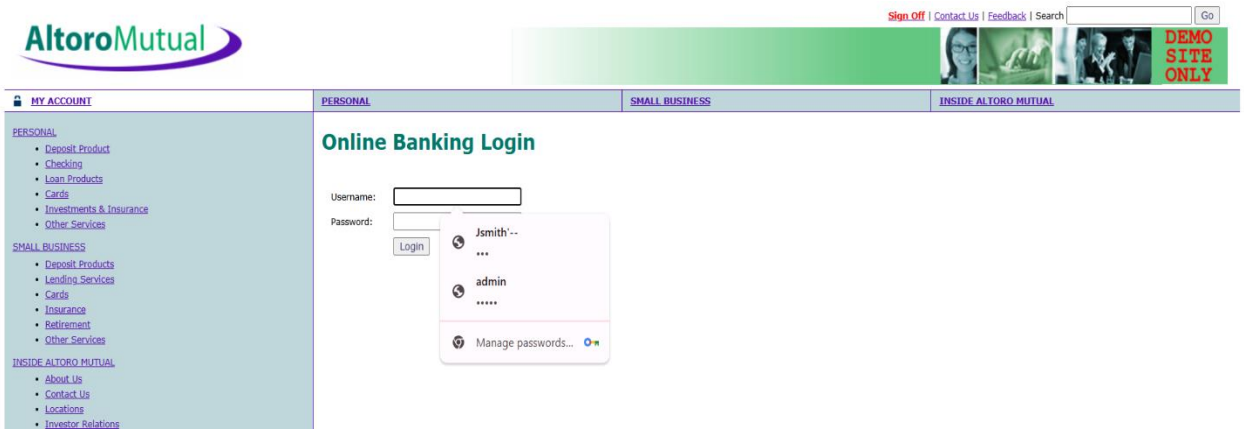
1. Open the website **http://testfire.net/**.
2. Navigate to the login page.
3. Click on the username or password field.
4. The browser automatically suggests stored credentials.

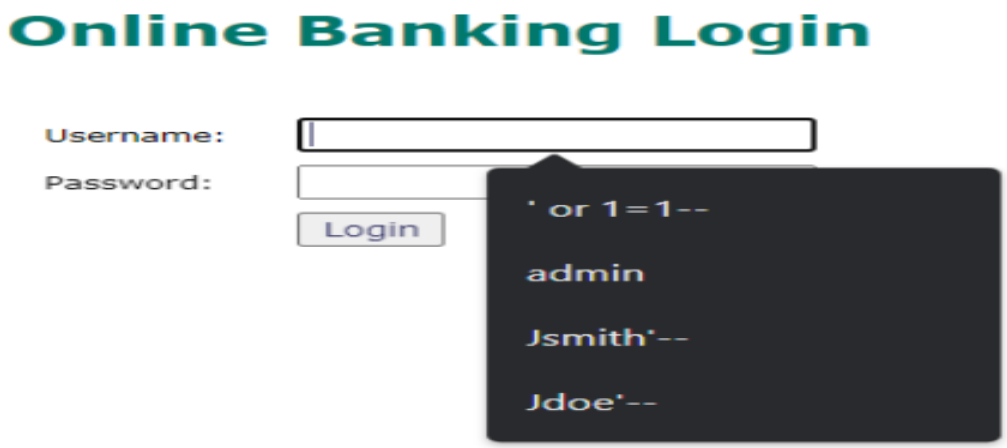
Recommendation :

Disable password auto-completion on login forms.

Use secure authentication mechanisms.

Screenshot :





11. Vulnerability Name : Cross-Site Scripting (DOM Based)

CWE No : CWE-79

Description : DOM-based XSS occurs when the client-side script processes user input and inserts it into the webpage without proper validation.

Business Impact : Attackers can execute malicious scripts in the user's browser and steal sensitive data such as session cookies.

Vulnerability Path : **https://vit.ac.in/**

Steps to Reproduce :

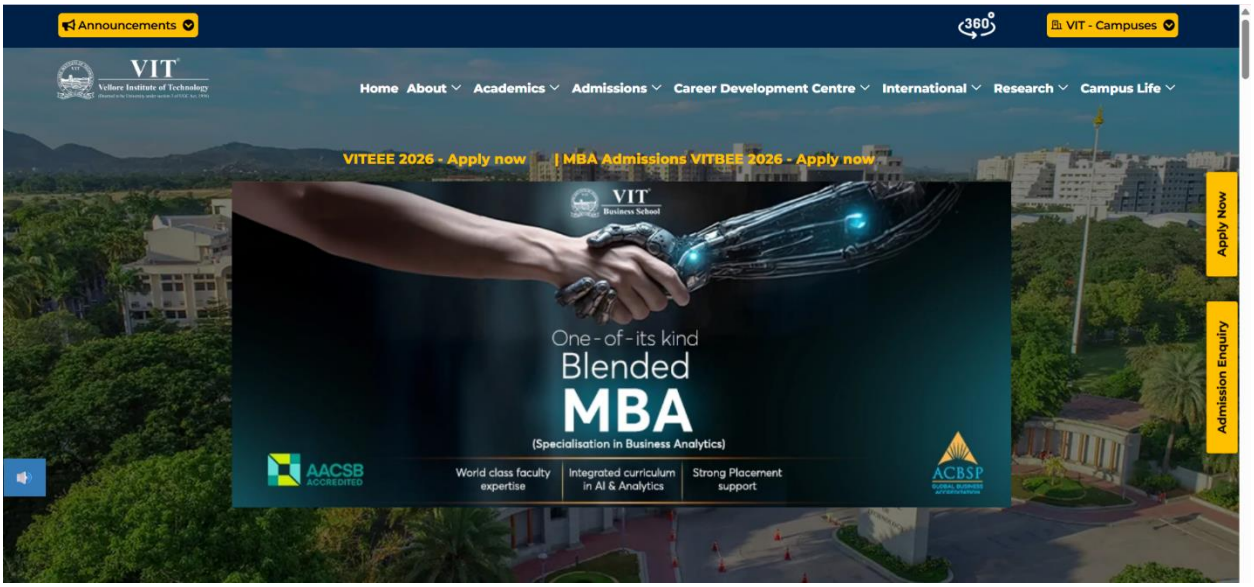
1. Open the website **https://vit.ac.in/**.
2. Inspect the page source using browser developer tools.
3. Identify places where user input is processed by JavaScript.
4. Inject malicious scripts to test for DOM manipulation.

Recommendation :

Validate and sanitize user inputs.

Avoid unsafe DOM manipulation methods.

Screenshot :



12. Vulnerability Name : JQuery Multiple XSS

CWE No : CWE-79

Description : This vulnerability occurs when outdated versions of JQuery contain security flaws that allow attackers to execute malicious scripts.

Business Impact : Attackers can exploit these vulnerabilities to run harmful scripts in the user's browser and steal sensitive data.

Vulnerability Path : **https://vit.ac.in/sites/all/themes/vittheme/js/jquery-2.1.1.min.js**

Steps to Reproduce :

Open the website **https://vit.ac.in/**.

Access the JQuery script used by the website.

Identify the JQuery version in the source code.

Older JQuery versions may contain XSS vulnerabilities.

Recommendation :

Update JQuery to the latest secure version.

Regularly update libraries used in web applications.

Screenshot :

13. **Vulnerability Name : Information Exposure (Web Server HTTP Header Internal IP Disclosure)**

CWE No : CWE-200

Description : This vulnerability occurs when the web server reveals internal IP addresses or system information in HTTP response headers.

Business Impact : Attackers can use this internal information to identify the system structure and plan further attacks on the network.

Vulnerability Path : https://vit.ac.in/

Steps to Reproduce :

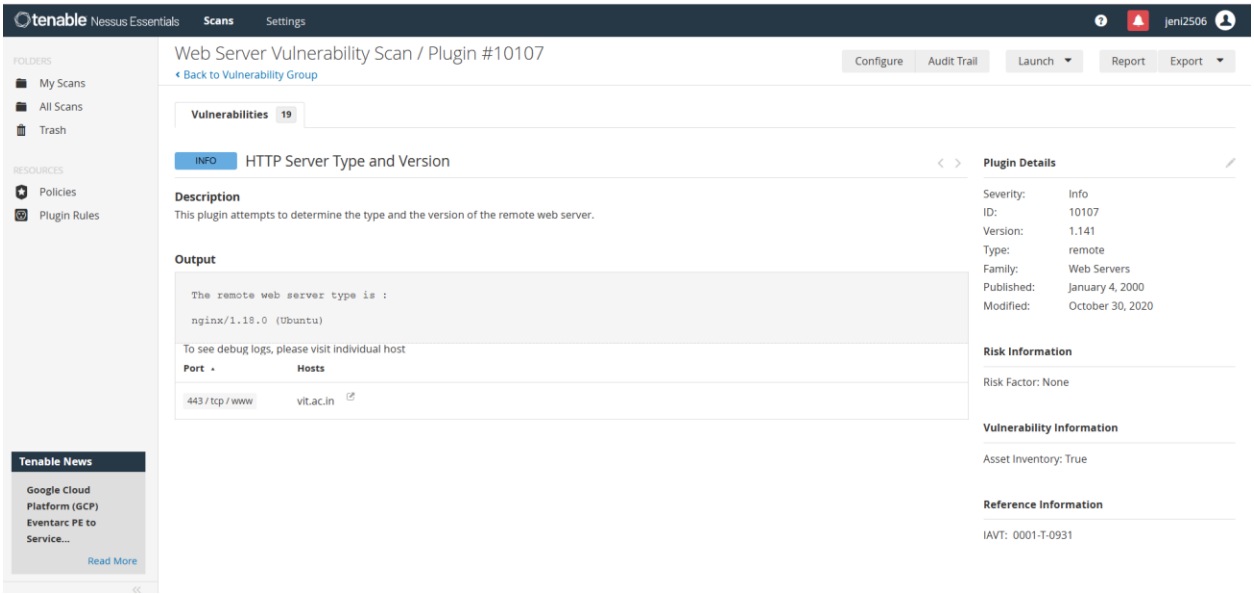
1. Open the target website.
2. Scan the website using Nessus vulnerability scanner.
3. Analyze the HTTP response headers.
4. The scan reveals the internal IP address of the server.

Recommendation :

Configure the web server to hide internal IP addresses.

Remove unnecessary information from HTTP response headers.

Screenshot :



14. Vulnerability Name : Information Exposure (SSL Multiple Issues)

CWE No : CWE-200

Description : This vulnerability occurs when the SSL/TLS configuration of a website exposes sensitive encryption details or uses weak security protocols.

Business Impact : Weak SSL configurations can allow attackers to intercept encrypted communication and access sensitive data.

Vulnerability Path : **https://vit.ac.in/**

Steps to Reproduce :

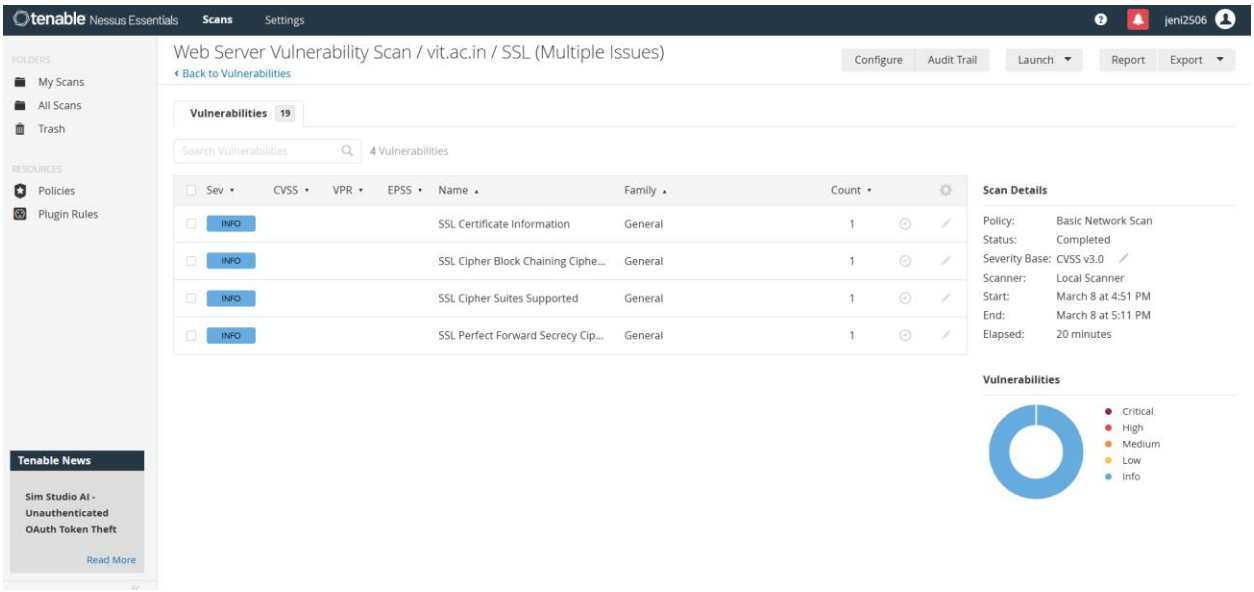
1. Open the target website.
2. Scan the website using Nessus vulnerability scanner.
3. Analyze the SSL/TLS configuration details.
4. The scan shows issues related to encryption protocols.

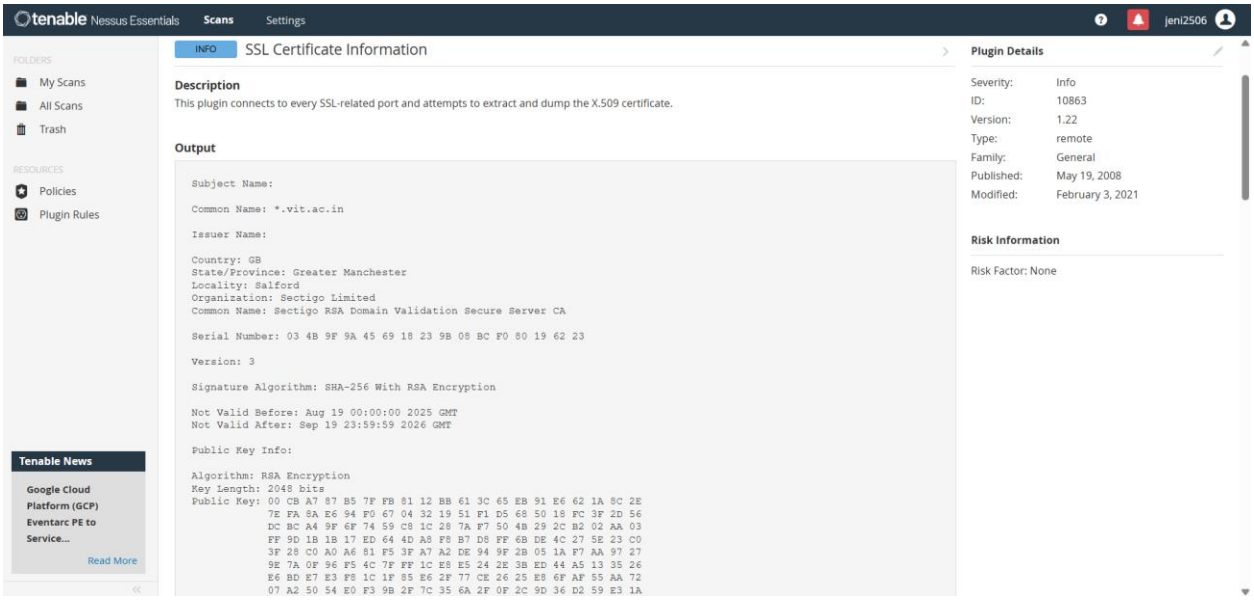
Recommendation :

Use strong encryption protocols such as TLS 1.2 or higher.

Disable outdated protocols like SSLv3.

Screenshot :





15. Vulnerability Name : Information Exposure (HTTP Multiple Issues)

CWE No : CWE-200

Description : This vulnerability occurs when the web server reveals unnecessary information through HTTP responses such as server details and protocol information.

Business Impact : Attackers can gather system information which may help them identify weaknesses and launch further attacks.

Vulnerability Path : **https://vit.ac.in/**

Steps to Reproduce :

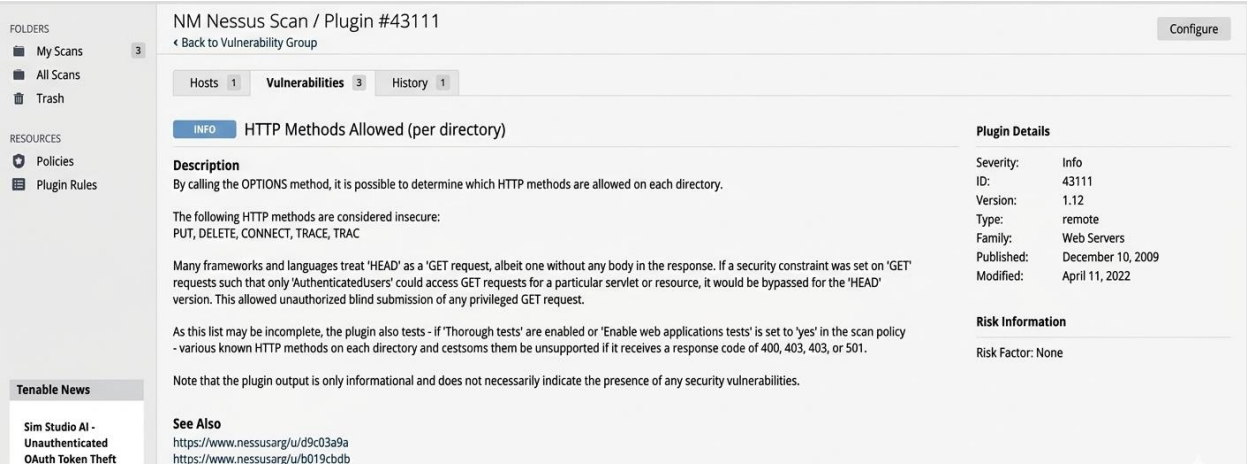
1. Open the target website.
2. Scan the website using Nessus scanner.
3. Review the HTTP response details.
4. The scan reveals server information and protocol details.

Recommendation :

Reduce unnecessary information in HTTP responses.

Use secure HTTPS configuration for communication.

Screenshot :



16. Vulnerability Name : OS Identification Failed

CWE No : CWE-200

Description : OS Identification Failed occurs when a vulnerability scanning tool cannot accurately detect the operating system of the target server.

Business Impact : Incorrect system identification may lead to improper security analysis and may hide potential vulnerabilities in the system.

Vulnerability Path : **https://vit.ac.in/**

Steps to Reproduce :

1. Open the target website.
2. Perform a vulnerability scan using Nessus scanner.
3. Analyze the scan results.
4. The scanner fails to identify the operating system of the target server.

Recommendation :

Ensure proper system configuration for accurate scanning.

Perform regular vulnerability assessments to detect security issues.

Screenshot :

STAGE 2

OVERVIEW:

This project focuses on improving network security using the principle of least-privilege access. It uses Zscaler Private Access (ZPA) to provide secure and identity-based access to internal applications. Instead of giving full network access, users are allowed to access only the applications they are authorized to use. The system verifies the user's identity and device security before granting access. This approach helps prevent unauthorized access and protects sensitive organizational data. The project also includes vulnerability assessment to identify security weaknesses in the system. Security monitoring concepts such as SOC and SIEM are studied to understand how organizations detect and respond to cyber threats. Overall, the project demonstrates how modern security solutions can improve network protection. Additionally, the project explores how secure access technologies can be implemented in a real organizational environment. It highlights the importance of continuous monitoring and threat intelligence to maintain strong cybersecurity defenses. The study also provides insights into how modern Zero Trust security models help organizations protect their networks from evolving cyber threats.

EXPLANATION OF TENABLE NESSUS:

Tenable Nessus is one of the most popular vulnerability scanning tools used by cybersecurity professionals. It helps organizations detect security weaknesses in networks, operating systems, databases, and applications.Nessus uses thousands of plugins to detect known vulnerabilities and security misconfigurations. It generates detailed reports that classify vulnerabilities based on severity levels such as **Low, Medium, High, and Critical**.

Key features include:

- Automated vulnerability scanning
- Risk prioritization
- Compliance checks
- Detailed remediation guidance
- Integration with security monitoring systems

The vulnerability assessment identified several security issues such as Cross-Site Scripting (XSS), information disclosure, and configuration-related weaknesses**.** By using the Nessus vulnerability scanner, organizations can detect these issues early and resolve them before they are exploited by attackers.

In this stage**,** vulnerability scanning and security evaluation were carried out to identify possible weaknesses in the target web application. The main goal of this phase is to detect security flaws that could allow unauthorized access or lead to the exposure of sensitive data.

Security testing was performed using vulnerability assessment tools like Nessus Scanner along with manual inspection methods. These tools assist in scanning the web server, identifying security vulnerabilities, and evaluating the overall security status of the application.

The scan results provide detailed information about the identified vulnerabilities and their corresponding severity level**s**, helping organizations prioritize and address critical security risks effectively.

VULNERABILITY TABLE:

The following table shows the vulnerabilities detected during the scanning process.

S.No	Vulnerability	Plugin	Port	Severity
1	Cross-Site Scripting (DOM Based XSS)	Multiple XSS	80 / 443	High
2	jQuery 1.3 < 3.5.0 Multiple XSS	CGI Abuse: XSS	80	High
3	Information Exposure (Web Server HTTP Header Internal IP Disclosure)	Web Server HTTP Header Internal IP Disclosure	80 / 443	Medium
4	Information Exposure (SSL Multiple Issues)	SSL Certificate Information	443	Medium
5	Information Exposure (HTTP Multiple Issues)	HTTP Information	80	Low
6	OS Identification Failed	TCP/IP Remote Probing	General	Low
7	SQL Injection	SQL Injection Vulnerability	80	Critical
8	Security Misconfiguration	Web Server Misconfiguration	80 / 443	Medium
9	Cross-Site Request Forgery (CSRF)	CSRF Detection	80 / 443	High
10	Cleartext Transmission of Sensitive Information	Sensitive Information Disclosure	80	High

1. Cross-Site Scripting (DOM Based XSS)

Plugin: Multiple XSS

Port: 80 / 443

Description: DOM-based Cross-Site Scripting (XSS) occurs when user input is processed directly in the browser using JavaScript without proper validation. Attackers can inject malicious scripts that execute in the victim's browser. These scripts may manipulate the webpage or steal sensitive information.

Solution:

Validate and sanitize all user inputs.

Avoid unsafe JavaScript functions.

Implement secure coding practices.

Business Impact: Attackers may steal session cookies, redirect users to malicious websites, or perform actions on behalf of the user.

2. jQuery 1.3 < 3.5.0 Multiple XSS

Plugin: CGI Abuse: XSS

Port: 80

Description: This vulnerability occurs when websites use outdated versions of the jQuery library. Older versions contain security flaws that allow attackers to execute Cross-Site Scripting attacks.

Solution:

Update jQuery to the latest version.

Regularly update third-party libraries.

Business Impact: Attackers may exploit the vulnerability to execute malicious scripts and compromise user data.

3. Information Exposure (Web Server HTTP Header Internal IP Disclosure)

Plugin: Web Server HTTP Header Internal IP Disclosure

Port: 80 / 443

Description: The web server exposes internal IP addresses through HTTP response headers. This information can reveal internal network details.

Solution:

Hide internal IP addresses in server headers.

Configure secure server settings.

Business Impact: Attackers can use internal information to plan further attacks on the network.

4.Information Exposure (SSL Multiple Issues)

Plugin: SSL Certificate Information

Port: 443

Description: The SSL/TLS configuration of the server reveals encryption details or uses outdated protocols.

Solution:

Use strong encryption protocols such as TLS 1.2 or TLS 1.3.

Disable insecure SSL protocols.

Business Impact: Weak encryption may allow attackers to intercept sensitive communication.

5. Information Exposure (HTTP Multiple Issues)

Plugin: HTTP Information

Port: 80

Description: The web server exposes unnecessary information such as server details and configuration through HTTP responses.

Solution:

Remove unnecessary HTTP headers.

Configure the web server securely.

Business Impact: Attackers can gather system information and exploit vulnerabilities.

6. OS Identification Failed

Plugin: TCP/IP Remote Probing

Port: General

Description: This issue occurs when the vulnerability scanner cannot determine the operating system of the target host.

Solution:

Configure systems properly for accurate scanning.

Perform regular vulnerability assessments.

Business Impact: Incorrect OS identification may limit accurate vulnerability detection.

7. SQL Injection

Plugin: SQL Injection Vulnerability

Port: 80

Description: SQL Injection occurs when attackers insert malicious SQL queries into input fields to manipulate the database.

Solution:

Use parameterized queries or prepared statements.

Validate and sanitize user inputs.

Business Impact: Attackers may access confidential data, modify database records, or gain unauthorized access.

8. Security Misconfiguration

Plugin: Web Server Misconfiguration

Port: 80 / 443

Description: Security Misconfiguration occurs when systems are configured improperly, allowing unauthorized access to files or directories.

Solution:

Apply secure server configurations.

Perform regular security audits.

Business Impact: Attackers may access confidential data or system files.

9. Cross-Site Request Forgery (CSRF)

Plugin: CSRF Detection

Port: 80 / 443

Description: CSRF attacks trick users into performing actions on a web application without their consent.

Solution:

Implement CSRF tokens.

Use secure session management.

Business Impact: Attackers may perform unauthorized actions such as changing data or transferring funds.

10. Cleartext Transmission of Sensitive Information

Plugin: Sensitive Information Disclosure

Port: 80

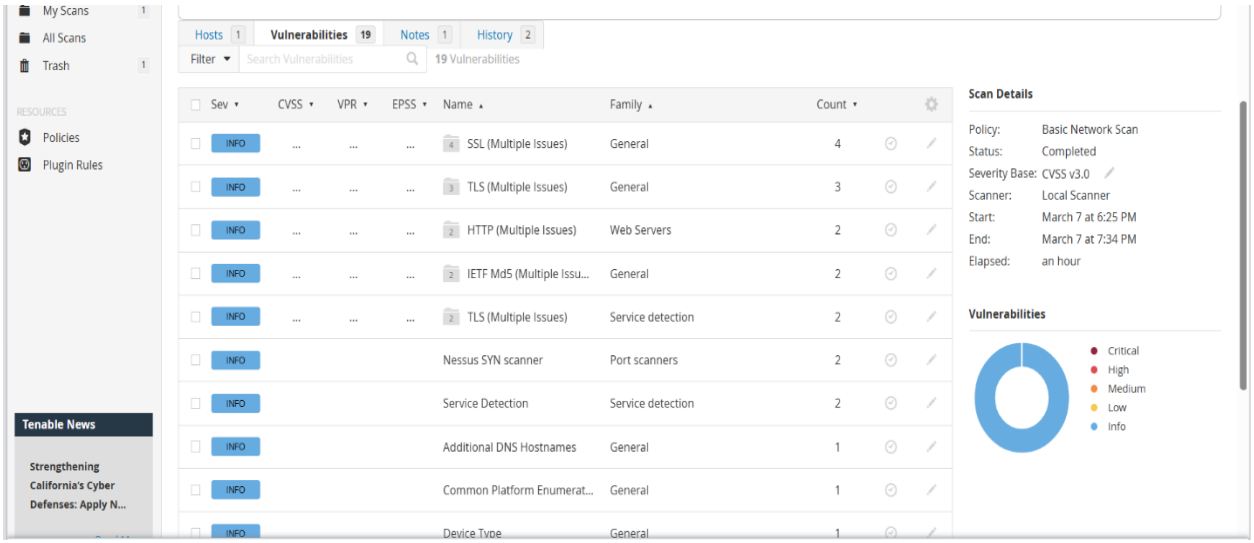
Description: Sensitive information such as usernames and passwords is transmitted without encryption.

Solution:

Use HTTPS with SSL/TLS encryption.

Avoid sending sensitive data through unsecured connections.

Business Impact: Attackers can intercept network traffic and steal sensitive information.



STAGE 3

Title: Security Operations Center (SOC) Implementation and Threat Intelligence Integration for Cybersecurity Monitoring

SOC (Security Operations Center)

A Security Operations Center (SOC) is a centralized unit that monitors, detects, and responds to cybersecurity threats in an organization. The SOC team uses various security tools to monitor network traffic, system logs, and suspicious activities. The main goal of SOC is to protect the organization's systems, applications, and data from cyber attacks. Security analysts in the SOC continuously analyze alerts and investigate potential threats. They also respond to incidents and take necessary actions to prevent further damage. SOC plays an important role in maintaining the overall security of the organization.

SOC Cycle

The SOC cycle represents the continuous process used to detect and respond to security threats.

1. **Monitoring** – Security tools continuously monitor network activity and system logs.
2. **Detection** – Suspicious activities and potential threats are identified.
3. **Analysis** – Security analysts investigate alerts to determine whether they are real threats.
4. **Response** – Actions are taken to stop or contain the attack.
5. **Recovery** – Systems are restored and security measures are improved.
6. **Reporting** – Incident reports are created to document the event and prevent future attacks.

SIEM (Security Information and Event Management)

SIEM stands for Security Information and Event Management. It is a security solution that collects and analyzes log data from various systems such as servers, firewalls, and applications. SIEM helps organizations detect suspicious activities by correlating data from multiple sources. It provides real-time monitoring and alerts when potential security threats are detected. Security teams use SIEM tools to analyze security events and respond quickly to incidents. SIEM also helps organizations maintain compliance with security standards.

SIEM Cycle

The SIEM cycle explains how security events are collected and analyzed.

1. **Log Collection** – Security logs are collected from different systems and devices.
2. **Log Management** – The logs are organized and stored securely.
3. **Event Correlation** – The system analyzes logs to identify suspicious patterns.
4. **Threat Detection** – Potential threats are detected based on predefined rules.
5. **Alert Generation** – Alerts are generated for security analysts.
6. **Incident Response** – The security team investigates and resolves the issue.

MISP (Malware Information Sharing Platform)

MISP stands for Malware Information Sharing Platform. It is an open-source platform used for sharing threat intelligence information between organizations. MISP helps security teams share data about malware, cyber attacks, and vulnerabilities. By sharing threat information, organizations can identify potential attacks early and improve their security defenses. MISP also helps in analyzing indicators of compromise such as malicious IP addresses or suspicious files. This improves collaboration between security teams and strengthens cybersecurity.

Our College Network Information

A college network usually consists of different systems connected together to support academic and administrative activities. These include computer labs, faculty systems, library servers, and student information systems. The network also includes internet connectivity, routers, switches, and wireless access points. Students and faculty members use the network for online learning, research, and communication. Because many users access the network daily, proper security measures are necessary to protect data and systems. Implementing secure access policies helps protect the college network from cyber threats.

How do I Plan to Deploy the Project

In this project, the security solution can be implemented in the college network to improve access control. Zscaler Private Access can be used to provide secure access to internal applications such as student portals and faculty systems. Users will first authenticate using secure login credentials. The system will verify their identity before allowing access to applications. Only authorized users will be able to access specific resources based on their roles. This approach will help protect the college network from unauthorized access and cyber-attacks.

Threat Intelligence

Threat intelligence is the process of collecting and analyzing information about potential cyber threats. It helps organizations understand attacker behavior and identify security risks before

attacks occur. Threat intelligence data may include malicious IP addresses, malware signatures, and vulnerability information. Security teams use this information to improve their defense strategies. By using threat intelligence, organizations can detect threats early and respond quickly to attacks. This helps in strengthening overall cybersecurity.

Types of Threat Intelligence:

- Strategic Threat Intelligence
- Tactical Threat Intelligence
- Operational Threat Intelligence
- Technical Threat Intelligence

RESULTS AND SECURITY RECOMMENDATIONS

After completing the vulnerability scanning and analysis process, several security issues were identified in the target web application. The vulnerability assessment was performed using tools such as Nessus Scanner, Burp Suite, and manual testing techniques. The scan results revealed different types of vulnerabilities including Cross-Site Scripting (XSS), outdated JavaScript libraries, information exposure through HTTP headers, and configuration-related issues.

The vulnerability scan categorized the issues into different severity levels such as Medium, Low, and Informational. Medium-level vulnerabilities like DOM-Based Cross-Site Scripting and outdated jQuery versions can allow attackers to execute malicious scripts in the user's browser. These vulnerabilities can potentially lead to session hijacking, data theft, or unauthorized access.

Low-level vulnerabilities such as HTTP header internal IP disclosure may expose sensitive server details. Attackers can use this information to better understand the system architecture and plan further attacks on the web server.

Informational vulnerabilities including SSL certificate details, HTTP information disclosure, and OS identification failures provide additional information about the server environment. While these vulnerabilities may not directly lead to attacks, they can assist attackers in gathering intelligence about the system.

To improve the overall security of the application, several security recommendations are suggested. Web developers should implement proper input validation and output encoding to prevent injection attacks such as Cross-Site Scripting. Outdated libraries such as older versions of jQuery should be updated to the latest secure versions to eliminate known vulnerabilities.

Additionally, server configuration should be improved by hiding sensitive HTTP headers and internal IP addresses. Secure communication protocols such as HTTPS with strong SSL/TLS encryption should be used to protect data transmitted over the network. Regular security testing and vulnerability scanning should also be performed to identify new threats and ensure continuous protection of the system.

By implementing these security practices, organizations can significantly reduce the risk of cyberattacks and maintain a secure environment for users and applications.

Future Scope

In the future, the project can be enhanced by integrating advanced security technologies such as artificial intelligence and machine learning for threat detection. Automated vulnerability scanning can also be implemented to identify security weaknesses continuously. Cloud-based security monitoring solutions can improve system scalability and performance. The project can also include advanced threat intelligence platforms for better threat analysis. Continuous improvement in security policies will further strengthen the network protection system.

TOOLS USED

The project involved the use of several cybersecurity tools and technologies to perform vulnerability scanning and security analysis.

Kali Linux : Kali Linux is a penetration testing operating system that contains a large collection of cybersecurity tools used for ethical hacking, vulnerability analysis, and network security testing. It provides an environment for performing security assessments on systems and web applications.

Nessus Vulnerability Scanner : Nessus is a widely used vulnerability scanning tool that detects security flaws, misconfigurations, and outdated software components in servers and web

applications. **Burp Suite :** Burp Suite is a web application security testing tool used to intercept, inspect, and modify HTTP requests and responses between the browser and the web server. It helps identify vulnerabilities such as SQL Injection, Cross-Site Scripting, and authentication issues.

Web Browser : A web browser such as Google Chrome or Mozilla Firefox is used to access the target web application and perform manual security testing. Browser developer tools help inspect web page elements and analyze scripts.

Uniscan Tool : Uniscan is a web vulnerability scanning tool used to detect hidden directories, configuration issues, and potential vulnerabilities in web applications.

Tools Explored

- Wireshark
- Nmap
- Metasploit
- OpenVAS
- MISP Platform

These tools provide advanced capabilities for network scanning, vulnerability detection, and threat analysis.

CONCLUSION

The main objective of this project was to design and apply context-aware access control concepts while performing vulnerability assessment on web applications. With the rapid growth of digital technologies and online services, cybersecurity has become an essential requirement for protecting sensitive data and system resources.

Through this project, various web application vulnerabilities were identified and analyzed using security testing tools. The vulnerability scanning process helped in understanding how attackers exploit weaknesses in web applications and how these vulnerabilities can impact the security of an organization.

The analysis revealed several vulnerabilities including Cross-Site Scripting, outdated software components, information exposure issues, and configuration weaknesses. Each vulnerability highlights the importance of implementing secure coding practices, proper system configuration, and regular security testing.

This project demonstrates the role of vulnerability assessment and security testing in improving application security. By identifying and addressing security weaknesses, organizations can prevent potential cyberattacks, protect user data, and maintain system integrity.

Overall, the project emphasizes the importance of proactive security measures, continuous monitoring, and regular vulnerability scanning to ensure a secure digital environment. Implementing strong security policies and modern access control mechanisms will help organizations protect their systems against evolving cyber threats.